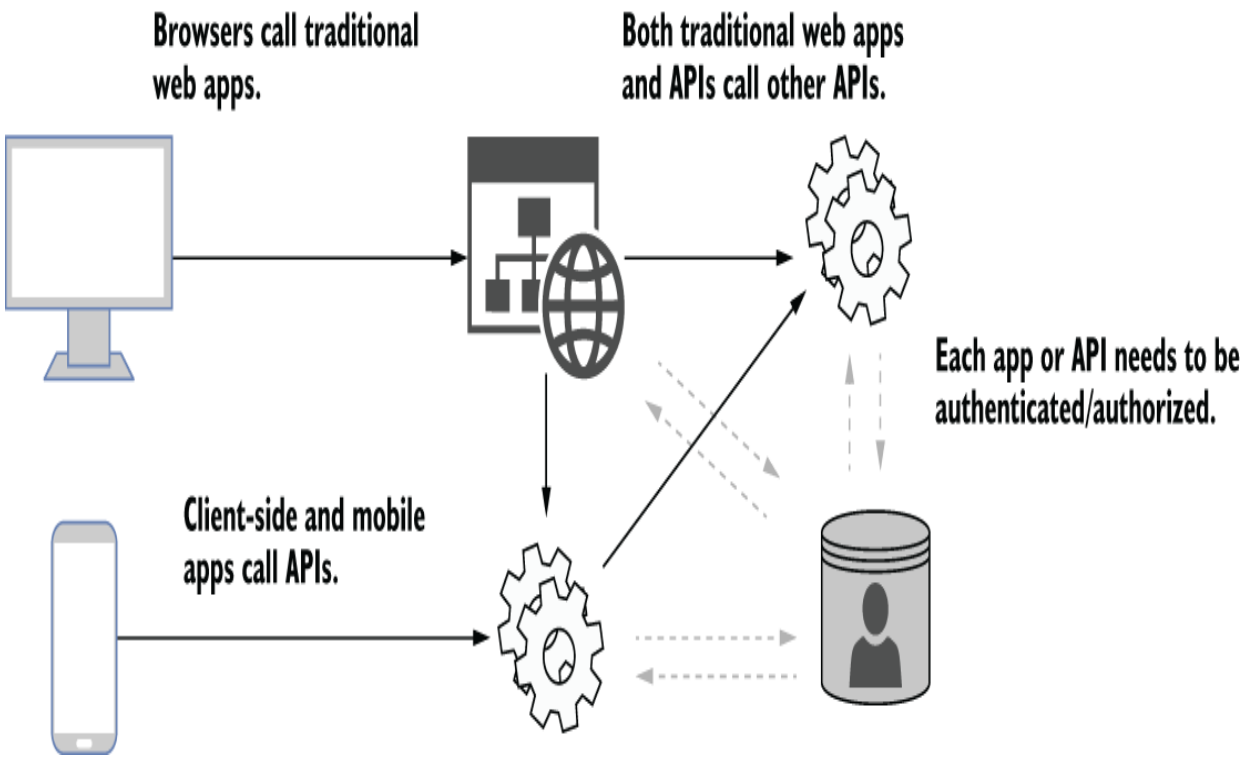


Figure 25.3 Modern applications typically need to expose web APIs for mobile and client-side apps, as well as potentially calling APIs on the backend. When all these services need to authenticate and manage users, this becomes logistically complicated.

In this situation you have multiple apps and APIs, all of which need to understand that the same user is logically making a request across all the apps and APIs. If you keep the same approach as before, where each app manages its own users, things can quickly become unmanageable!

You'd need to duplicate all the sign-in logic between the apps and APIs, as well as have some central database holding the user details. Users would likely need to sign in multiple times to access different parts of the service. On top of that, using cookies becomes problematic for some mobile clients in particular or where you're making requests to multiple domains (as cookies belong to only a single domain). So how can we improve this? By moving the authentication responsibilities to a separate service.